

ATOMIC RED TEAM, CONFIGURACIÓN Y DEMO

RESUMEN

En la parte anterior de la serie, desplegamos MITRE Caldera para introducir la emulación de adversarios y pruebas de seguridad automatizadas en el laboratorio doméstico. Ahora, estamos llevando esa capacidad aún más allá integrando **Atomic Red Team**, uno de los frameworks más utilizados y ligeros para ejecutar técnicas individuales de MITRE ATT&CK en un entorno seguro y controlado.

Esta sección se centra en:

1. Instalación **de Atomic Red Team** y el **módulo PowerShell** de Invoke-AtomicRedTeam
2. Preparando Windows 11 para ejecutar pruebas atómicas
3. Ejecutar una técnica real de ATT&CK de extremo a extremo
4. Validación de la detección en **Splunk**
5. Limpieza posterior a la ejecución usando scripts de limpieza atómica integrados

Atomic Red Team te ofrece pruebas precisas, repetibles y granulares similares a las que harías durante los enfrentamientos de red team, ejercicios de equipo morado o flujos de trabajo de detección de ingeniería. Es el complemento ideal para Caldera y una herramienta crítica para validar que tus pipelines de registro, telemetría y SIEM funcionan como se espera.

ATOMIC RED TEAM SETUP

En esta sección, utilizaremos el método manual de instalación local, que te da el mayor control y visibilidad sobre cómo está estructurado Atomic Red Team.

DESCARGAR ARCHIVOS REQUERIDOS

Para empezar, descarga ambos componentes desde GitHub:

a) Repositorio "Atomics" del Atomic Red Team:

Este contiene las definiciones de pruebas atómicas, archivos de entrada, cargas útiles y estructura para cada técnica MITRE.

- GitHub: <https://github.com/redcanaryco/atomic-red-team>

b) Módulo PowerShell Invoke-AtomicRedTeam:

Este módulo PowerShell ejecuta las pruebas atómicas, gestiona dependencias y gestiona las operaciones de limpieza.

- GitHub: <https://github.com/redcanaryco/invoke-atomicredteam>

PREPARACIÓN DE CARPETAS

Crea una estructura de directorios limpia para que todo lo relacionado con Atomic Red Team esté en un solo lugar.

```
C:\AtomicRedTeam
```

Coloca ambos ZIPs aquí:

```
C:\AtomicRedTeam\atomic-red-team-master.zip  
C:\AtomicRedTeam\invoke-atomicredteam-master.zip
```

Extrae ambos archivos.

Después de la extracción, asegúrate de que la estructura de carpetas sea así:

```
C:\AtomicRedTeam\atomics\  
C:\AtomicRedTeam\invoke-atomicredteam\
```

Consejo: Evita las carpetas anidadas. Si acabas con C:\AtomicRedTeam\atomic-red-team-master\atomics\, sube **solo** la carpeta de atómicos un nivel.

REQUISITOS DE INSTALACIÓN DE POWERSHELL

Antes de ejecutar cualquier cosa, tendrás que modificar los permisos de ejecución e instalar los módulos necesarios.

a) Permitir la ejecución de scripts

```
Set-ExecutionPolicy -ExecutionPolicy Bypass -Scope CurrentUser
```

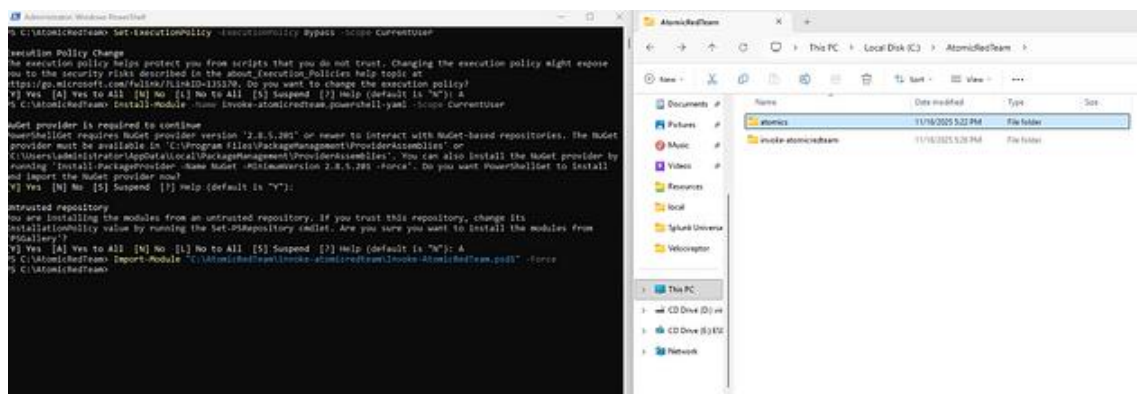
b) Instalar los módulos PowerShell requeridos

```
Install-Module -Nombre invoke-atomicredteam,powershell-yaml -Scope  
CurrentUser
```

c) Importar el módulo

```
Import-módulo "C:\AtomicRedTeam\invoke-atomicredteam\Invoke-  
AtomicRedTeam.psd1" -Force
```

En este punto, Windows debería reconocer el comando Invoke-AtomicTest.



INSTALACIÓN DE ATOMIC & PRERREQUISITOS / ESTRUCTURA DE CARPETAS

USO: LISTADO Y EJECUCIÓN DE ATOMICS

Una de las mejores partes de Atomic Red Team es lo fácil que es explorar las técnicas disponibles.

PRE-TRABAJO — ENCONTRAR UN TEST

Ver todas las pruebas atómicas

```
Invoke-AtomicTest All -ShowDetailsBrief
```

Ver pruebas para una técnica específica de MITRE

- Ejemplo: T1553.005 — Subvertir controles de confianza: Bypass de marca de la web

```
Invoke-AtomicTest T1553.005 -ShowDetailsBrief
```

Mostrar detalles completos

```
Invoke-AtomicTest T1553 -ShowDetails
```

REALIZANDO UNA PRUEBA ATÓMICA REAL

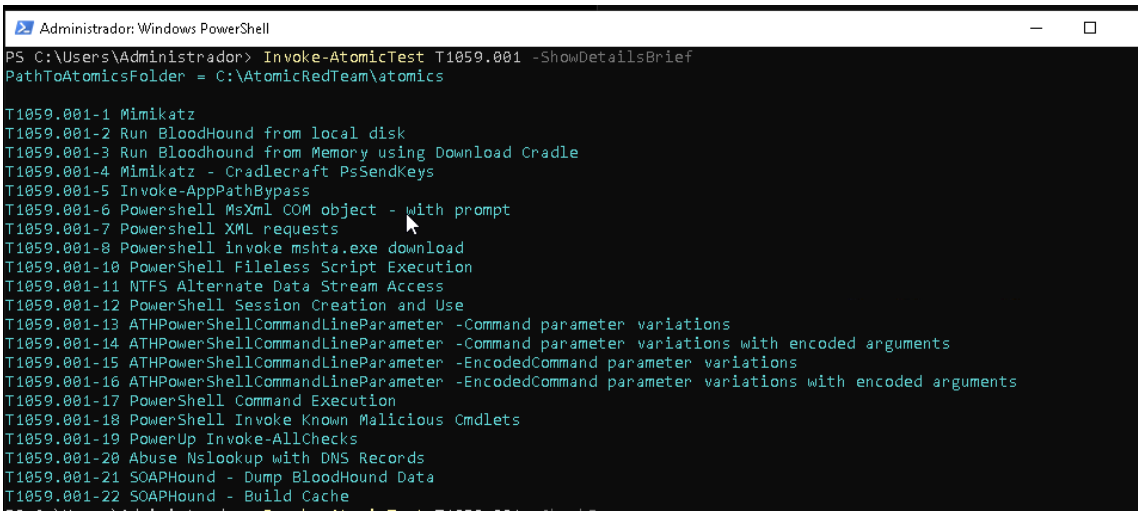
Para validar que el registro funciona correctamente (especialmente Security Onion o tu SIEM), ejecutaremos **T1059.001 — Usar powershell** para ejecutar código malicioso.

Consulta la prueba antes de ejecutarla

- Esto es importante. Revisa siempre lo que hace el examen para entender el impacto esperado.

```
Invoke-AtomicTest T1059.001 -ShowDetails
```

- Esta técnica incluye múltiples pruebas. Esta técnica describe **cómo los atacantes utilizan PowerShell (una herramienta legítima y nativa de Windows) para ejecutar código malicioso, moverse dentro de una red o robar información**, aprovechando que el sistema operativo ya confía en ella.



```
PS C:\Users\Administrador> Invoke-AtomicTest T1059.001 -ShowDetailsBrief
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

T1059.001-1 Mimikatz
T1059.001-2 Run BloodHound from local disk
T1059.001-3 Run Bloodhound from Memory using Download Cradle
T1059.001-4 Mimikatz - Cradlecraft PsSendKeys
T1059.001-5 Invoke-AppPathBypass
T1059.001-6 Powershell MsXml COM object - with prompt
T1059.001-7 Powershell XML requests
T1059.001-8 Powershell invoke mshta.exe download
T1059.001-10 Powershell Fileless Script Execution
T1059.001-11 NTFS Alternate Data Stream Access
T1059.001-12 Powershell Session Creation and Use
T1059.001-13 ATHPowerShellCommandLineParameter -Command parameter variations
T1059.001-14 ATHPowerShellCommandLineParameter -Command parameter variations with encoded arguments
T1059.001-15 ATHPowerShellCommandLineParameter -EncodedCommand parameter variations
T1059.001-16 ATHPowerShellCommandLineParameter -EncodedCommand parameter variations with encoded arguments
T1059.001-17 Powershell Command Execution
T1059.001-18 Powershell Invoke Known Malicious Cmdlets
T1059.001-19 PowerUp Invoke-AllChecks
T1059.001-20 Abuse Nslookup with DNS Records
T1059.001-21 SOAPHound - Dump BloodHound Data
T1059.001-22 SOAPHound - Build Cache
```

EJECUTAR LA PRUEBA ATÓMICA

Invoke-AtomicTest T1059.001 -TestNumbers 1

```
Administrador: Windows PowerShell
PS C:\Users\Administrador> Invoke-AtomicTest T1059.001 -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T1059.001-1 Mimikatz
.#####. mimikatz 2.2.0 (x64) #18362 Oct 30 2019 13:01:25
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/
mimikatz(powershell) # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Logon list
mimikatz(powershell) # exit
Bye!
Exit code: 0
Done executing test: T1059.001-1 Mimikatz
PS C:\Users\Administrador>
```

La prueba **T1059.001-1** de Atomic Red Team se titula comúnmente "**Invoke-Mimikatz**".

Esta prueba está diseñada para simular una de las acciones más críticas y comunes que realiza un atacante después de comprometer un sistema Windows: **el robo de credenciales**.

Aquí te explico exactamente qué hace esta prueba paso a paso, por qué se utiliza y qué valida en tu entorno:

¿Qué hace exactamente la prueba T1059.001-1?

1. **Descarga en memoria (Download Cradle):** El comando utiliza PowerShell para conectarse a una URL remota (históricamente un repositorio de GitHub como PowerSploit o el propio de Atomic Red Team) y descargar el script Invoke-Mimikatz.ps1. Lo hace utilizando comandos como IEX (Invoke-Expression) combinado con IWR (Invoke-WebRequest). *Clave:* El script **nunca se guarda en el disco duro**; se carga y ejecuta directamente en la memoria RAM del equipo.
2. **Ejecución del payload:** Inmediatamente después de cargar el script en memoria, PowerShell ejecuta la función Invoke-Mimikatz, generalmente con parámetros como -DumpCreds.
3. **Interacción con LSASS:** El script intenta inyectarse o leer la memoria del proceso **lsass.exe** (Local Security Authority Subsystem Service). Este es el proceso de Windows encargado de gestionar la seguridad local y almacenar temporalmente las credenciales de los usuarios que han iniciado sesión (contraseñas en texto plano, hashes NTLM y tickets de Kerberos).

¿Cuál es el propósito defensivo de ejecutar esta prueba?

Los equipos de seguridad (Blue Teams) ejecutan esta prueba no para robar credenciales reales, sino para **validar que sus controles de seguridad funcionan**. Específicamente, verifica:

1. **Detección de "Download Cradles":** ¿El firewall, el proxy o el EDR detectan y bloquean la descarga de scripts de PowerShell desde repositorios conocidos de herramientas de hacking?
2. **Eficacia de AMSI (Antimalware Scan Interface):** AMSI escanea el contenido de los scripts *después* de que han sido descriptados o decodificados en la memoria. Un EDR moderno debería detectar la cadena de texto "Invoke-Mimikatz" o las firmas del código de Mimikatz en el momento en que PowerShell intenta ejecutarlo, bloqueándolo antes de que haga daño.
3. **Protección de LSASS:** Valida si el sistema tiene habilitadas protecciones como **Windows Defender Credential Guard** o reglas de prevención de acceso a lsass.exe. Si están bien configuradas, la prueba fallará al intentar leer la memoria, generando una alerta de "Protección de credenciales".
4. **Registro (Logging):** Verifica que el "Script Block Logging" de PowerShell esté capturando el comando completo en el Visor de Eventos de Windows (Event ID 4104), permitiendo a los analistas ver qué intentó ejecutar el atacante.

VALIDACIÓN DE RESULTADOS EN SECURITY ONION

QUERIES PARA HUNT EN SECURITY ONION

Opción 1 — Sysmon Event ID 1 (Process Creation)

```
event.code:1 AND host.name:"dc01" AND process.name:"powershell.exe"
```

Con flags sospechosos (los que usa Atomic):

```
event.code:1 AND host.name:"dc01" AND  
winlog.event_data.CommandLine>(*bypass* OR *encodedCommand* OR *nop*  
OR *hidden*)
```

Opción 2 — PowerShell ScriptBlock Logging (Event 4104)

```
event.code:4104 AND host.name:"dc01"
```

Esto captura el contenido real del script ejecutado, es el más valioso para ver qué hizo exactamente.

Opción 3 — Windows nativo (Event 4688)

```
event.code:4688 AND host.name:"dc01" AND process.name:"powershell.exe"
```

The screenshot shows the Security Onion web interface. The search bar at the top contains the query: `event.code:1 AND host.name:"dc01" AND process.name:"powershell.exe"`. Below the search bar, there are tabs for "Basic Metrics" and "Events". The "Events" tab is selected, showing a list of events. The table has columns for Timestamp, Event Name, Action, Computer Name, User Name, Process Name, and Process ID. The events listed are all "Process creation" events for "powershell.exe" on "DC01 lab local" by the "Administrator" user.

Timestamp	Event Name	Action	Computer Name	User Name	Process Name	Process ID
2026-06-04 20:12:29.075 +02:00	windows.system_operational	Process creation	DC01 lab local	Administrator	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	9148
2026-06-04 20:12:11.023 +02:00	windows.system_operational	Process creation	DC01 lab local	Administrator	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	8428
2026-06-04 20:12:09.893 +02:00	windows.system_operational	Process creation	DC01 lab local	Administrator	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	824
2026-06-04 20:12:08.813 +02:00	windows.system_operational	Process creation	DC01 lab local	Administrator	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe	9236

LIMPIEZA

Atomic Red Team incluye procedimientos de limpieza que revierten los cambios que la prueba haya provocado.

```
Invoke-AtomicTest T1059.001 -Cleanup -TestNumbers 1
```

```
PS C:\Users\Administrador> Invoke-AtomicTest T1059.001 -Cleanup -TestNumbers 1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing cleanup for test: T1059.001-1 Mimikatz
Done executing cleanup for test: T1059.001-1 Mimikatz
PS C:\Users\Administrador> _
```

RESUMEN

En esta sección, desplegaste con éxito Atomic Red Team dentro de tu entorno Windows y ejecutaste una técnica real de MITRE ATT&CK de principio a fin. Preparaste la estructura de archivos, instalaste el módulo PowerShell, exploraste las técnicas disponibles y ejecutaste (y luego limpiaste) una prueba atómica de persistencia de dominio.

Lo más importante es que verificaste que tu canal de telemetría y eventos SIEM, en este caso Security Onion, capturó exactamente los eventos que la técnica debería generar. Esta es la base para construir detecciones de alta fidelidad y validar que las herramientas SOC funcionan de extremo a extremo.